

Al-Jazeera Financial Company (AJFC)

Comprehensive Cybersecurity Policy Manual

SAMA Cyber Security Framework (CSF) v1.0 — Full Alignment Edition

Document Ref:	AJFC-SEC-MASTER-001	Version:	5.0
Effective Date:	01 January 2025	Next Review:	01 January 2026
Classification:	Confidential — Internal	Pages:	~30
Approved By:	Board Cybersecurity Committee	Owner:	CISO
Issuing Authority:	Office of the CISO	Regulation:	SAMA CSF v1.0

This document constitutes the master cybersecurity policy manual for Al-Jazeera Financial Company (AJFC), a licensed financial institution operating under the regulatory supervision of the Saudi Central Bank (SAMA). The manual has been developed in full alignment with the SAMA Cyber Security Framework (CSF) Version 1.0, which establishes mandatory cybersecurity requirements for all financial entities in the Kingdom of Saudi Arabia. This edition supersedes all previous policy versions and incorporates lessons learned from internal audits, SAMA examination findings, and industry best practices.

The manual is structured to address all five SAMA CSF domains: Cybersecurity Leadership and Governance, Cybersecurity Risk Management and Compliance, Cybersecurity Operations and Technology, Third-Party Cybersecurity, and Cybersecurity Resilience. Each chapter maps directly to the applicable SAMA CSF sub-domains and associated controls, providing a clear audit trail of compliance evidence.

1.1 Policy Statement and Commitment

The Board of Directors of Al-Jazeera Financial Company formally endorses this Cybersecurity Policy Manual as the cornerstone of the organisation's commitment to protecting information assets, customer data, and the integrity of the financial system. The Board recognises that cyber risk is a principal business risk and has embedded cybersecurity oversight into its committee structure.

Senior management is accountable for implementing this policy throughout the organisation and for ensuring all staff understand and fulfil their cybersecurity obligations. Resources—financial, human, and technological—are allocated proportionate to the risk environment and regulatory requirements.

1.2 Governance Structure

AJFC operates a three-tier governance model ensuring strategic oversight cascades through tactical management to operational execution:

Tier	Body	Key Responsibilities	Meeting Cadence
Strategic	Board Cybersecurity Committee	Risk appetite; budget approval; regulatory accountability; CISO appointment	Quarterly
Tactical	Cybersecurity Steering Committee	Regulatory oversight; policy approval; P1 incident escalation; vendor risk	Monthly
Operational	CISO & Security Operations	Daily controls management; monitoring; threat response; reporting	Weekly

1.3 Roles & Responsibilities

Board of Directors

- Approve cybersecurity risk appetite statement and review annually.
- Receive and challenge quarterly cybersecurity reports from the CISO.
- Ensure cybersecurity is a standing agenda item at Board meetings.
- Approve significant cybersecurity investments exceeding SAR 2 million.
- Hold management accountable for SAMA CSF compliance.

Chief Executive Officer

- Champion cybersecurity culture and tone-from-the-top messaging.
- Chair the monthly Cybersecurity Steering Committee.
- Authorise the annual cybersecurity budget allocation.
- Approve and communicate the enterprise cybersecurity strategy.

Chief Information Security Officer (CISO)

- Develop, maintain, and enforce the cybersecurity programme.
- Present quarterly cybersecurity posture report to the Board.
- Own the SAMA CSF compliance mapping and gap remediation plan.
- Manage the SOC, Incident Response, and Vulnerability Management functions.
- Authorise security exceptions and risk acceptances.

- Liaise with SAMA, NCA, and other regulators.

IT Department

- Implement and maintain technical security controls per CISO direction.
- Execute the patch management programme within defined SLAs.
- Manage identity and access management (IAM) systems.
- Maintain system availability and support BCP/DR testing.
- Provide security-relevant log data to the SIEM/SOC.

Human Resources

- Enforce background screening for all new permanent hires.
- Notify IT within 24 hours of joiners, movers, and leavers.
- Ensure cybersecurity awareness training completion is tracked via LMS.
- Include cybersecurity obligations in all employment contracts.

All Employees and Contractors

- Complete mandatory annual cybersecurity awareness training (≥90% pass mark).
- Report any suspected security incidents, phishing, or anomalies immediately.
- Comply with all cybersecurity policies, standards, and procedures.
- Safeguard company devices, credentials, and information assets at all times.
- Refrain from installing unauthorised software or accessing prohibited websites.

1.4 Policy Management Lifecycle

All cybersecurity policies follow a structured lifecycle to ensure they remain current, relevant, and enforceable:

Stage	Activity	Responsibility	Frequency
1 — Initiation	Identify need for new/revised policy	CISO / Policy Owner	As required
2 — Drafting	Draft policy with SME input	Policy Owner + Security Team	Per schedule
3 — Review	Legal, Compliance, and IT review	Legal + Compliance + IT	Per draft
4 — Approval	CISO approval; CEO sign-off for T&S policies	CISO Office	Before publication
5 — Communication	Publish to intranet; brief affected teams	HR Communications	At publication
6 — Training	Update awareness training content	Learning & Development	Within 30 days
7 — Review	Annual review cycle or triggered review	Policy Owner	Annual minimum
8 — Retirement	Archive superseded versions with CISO Office	CISO Office	As required

1.5 Regulatory Compliance Landscape

AJFC operates within a complex regulatory environment. The following regulations and frameworks govern the company's cybersecurity obligations:

Regulation / Framework	Issuing Body	Scope	Compliance Status
SAMA Cyber Security Framework (CSF)	Saudi Central Bank	Mandatory — all SAMA-regulated entities	Fully Mapped
SAMA Cloud Computing Framework	Saudi Central Bank	Mandatory — cloud adopters	Fully Mapped

Personal Data Protection Law (PDPL)	SDAIA	Mandatory — personal data protection	Fully Mapped
NCA Essential Cybersecurity Controls (NECC-2024)	NECC	Applicable — public/private sector	Partially Mapped
NCA Cloud Cybersecurity Controls (CSCA)	CSCA	Applicable — cloud deployment	Partially Mapped
ISO/IEC 27001:2022	ISO	Voluntary / Best Practice	Reference Standard
PCI DSS v4.0	PCI SSC	Mandatory — card payments	Fully Mapped
SWIFT Customer Security Programme (SCSP)	SCSP	Mandatory — SWIFT connectivity	Fully Mapped

2.1 Risk Management Philosophy

AJFC adopts a risk-based approach to cybersecurity, ensuring that controls are prioritised and resources allocated commensurate with the risk profile of the organisation. The cybersecurity risk management programme is integrated with the enterprise risk management (ERM) framework and aligned to the SAMA CSF maturity requirements.

The target maturity level across all SAMA CSF domains is Level 4 (Managed and Measurable), with critical processes targeting Level 5 (Optimised). Current maturity levels are assessed annually by an independent third party and reported to the Board.

2.2 Risk Appetite Statement

The Board has formally approved the following risk appetite statements for cybersecurity risk:

- **ZERO TOLERANCE:** Unauthorised disclosure of customer financial data or personally identifiable information (PII).
- **ZERO TOLERANCE:** Wilful non-compliance with SAMA regulations or deliberate circumvention of controls.
- **LOW TOLERANCE:** Cybersecurity incidents causing core banking or payment system outages exceeding RTO thresholds.
- **LOW TOLERANCE:** Repeated or unmitigated control failures identified in internal or external audits.
- **MODERATE TOLERANCE:** Emerging technology adoption risk, subject to mandatory risk assessment and compensating controls.
- **MODERATE TOLERANCE:** Residual risk from third-party relationships where contractual controls are in place.

2.3 Risk Assessment Methodology

Risk assessments are conducted using a qualitative 5×5 likelihood-impact matrix. Each risk is scored by multiplying the likelihood score (1–5) by the impact score (1–5), producing a risk rating of: Low (1–4), Medium (5–9), High (10–14), and Critical (15–25).

Likelihood \ Impact	Negligible (1)	Minor (2)	Moderate (3)	Major (4)	Catastrophic (5)
Almost Certain (5)	5 — Medium	10 — High	15 — Critical	20 — Critical	25 — Critical
Likely (4)	4 — Low	8 — Medium	12 — High	16 — Critical	20 — Critical
Possible (3)	3 — Low	6 — Medium	9 — Medium	12 — High	15 — Critical
Unlikely (2)	2 — Low	4 — Low	6 — Medium	8 — Medium	10 — High
Rare (1)	1 — Low	2 — Low	3 — Low	4 — Low	5 — Medium

2.4 Risk Assessment Schedule

Assessment Type	Scope	Trigger / Frequency	Owner	Reporting To
-----------------	-------	---------------------	-------	--------------

Enterprise Cyber Risk Assessment	All information assets and systems	Annual or as material changes	CISO	Board & CEO
Third-Party Risk Assessment	All vendors with data / systems access	Onboarding + annual	Procurement + CISO	Steering Committee
Application Security Assessment	New / significantly changed	Pre-release / change	IT + CISO	CISO
Cloud Security Review	All cloud environments (IaaS/PaaS/SaaS)	Quarterly	IT + CISO	CISO
External Penetration Test	All internet-facing systems	Annual	CISO (contracted)	Board
Internal Penetration Test	Internal network, Active Directory	Annual	CISO (contracted)	Board
Red Team Exercise	Full kill-chain simulation	Bi-annual	CISO (contracted)	Board
Vulnerability Scanning	All network and server assets	Weekly (automated)	SOC	CISO
Business Impact Analysis	All critical business processes	Annual	BCM Team	CEO
SAMA CSF Maturity Assessment	All CSF domains	Annual (external assessment)	CISO	Board + SAMA

2.5 Risk Treatment and Escalation

Risk Rating	Treatment Requirement	Escalation	Review Frequency
Critical (15–25)	Mandatory immediate treatment plan; CISO approval required	Board / CEO notification within 24 hours	Monthly
High (10–14)	Treatment plan within 30 days; CISO sign-off	Steering Committee	Quarterly
Medium (5–9)	Treatment plan within 90 days; IT Manager sign-off	CISO	Quarterly
Low (1–4)	Accepted or treated as part of normal operations	IT Manager	Annually

2.6 Compliance Monitoring

Compliance with this policy and associated standards is monitored through multiple mechanisms:

- Internal audit conducts an annual cybersecurity audit covering a risk-based sample of controls.
- The CISO produces a monthly cybersecurity compliance dashboard reviewed by the Steering Committee.
- SAMA examination findings are tracked to closure with evidence submitted within agreed timeframes.
- Automated compliance checks are performed via the GRC platform for technical controls.
- Employees found in breach of cybersecurity policies are subject to disciplinary action per HR policy.

Chapter 3 — Identity & Access Management

3.1 Access Control Principles

- Least Privilege: Users are granted the minimum access necessary to perform their role.
- Need-to-Know: Access to sensitive data is restricted to those with a business justification.
- Separation of Duties: No single individual should have end-to-end control over a critical process.
- Default Deny: Systems deny access by default; access is explicitly granted following approval.
- Accountability: All access and actions are logged and attributable to a named individual.

3.2 User Lifecycle Management

Event	Trigger	Action Required	SLA	Responsible
Joiner	HR sends offer acceptance	Create accounts; assign role-based access	2 business days	IT + HR
Internal Transfer	HR sends transfer notification	Review and modify access rights	5 business days	IT + Line Manager
Promotion	HR sends grade change	Review privileged access entitlements	5 business days	IT + CISO
Leaver (Resignation)	HR sends leaver notice	Disable all accounts on last working day	Same day	IT + HR
Leaver (Termination)	HR / Legal immediate notice	Disable all accounts immediately	Within 1 hour	IT + CISO
Contractor Onboard	Procurement confirms contract	Create time-limited access; No PAM	2 business days	IT + Procurement
Contractor Off-board	Procurement confirms contract end	Revoke all access immediately	Same day	IT

3.3 Password and Authentication Standards

Access Type	Min Length	Complexity	Rotation	MFA Required	Failed Attempt Lock
Standard user (internal)	12 chars	Upper, lower, number, 1 symbol	90 days	No (intranet only)	5 attempts → 30 min lock
Remote access / VPN	14 chars	Upper, lower, number, 2 symbols	90 days	YES — TOTP app	5 attempts → 60 min lock
Privileged / Admin accounts	16 chars	Upper, lower, number, 3 symbols	30 days (PAM auto-rotate)	YES — Hardware	3 attempts → CISO alert
Core banking system	14 chars	Upper, lower, number, 2 symbols	60 days	YES — Hardware	3 attempts → account lock
Cloud management console	16 chars	Upper, lower, number, 2 symbols	90 days	YES — TOTP app	5 attempts → 30 min lock
Customer-facing portal	8 chars minimum	Lower + number minimum 2	65 days	YES — OTP SMS	5 attempts → CAPTCHA
Service / System accounts	20+ chars (generated)	High-entropy	Automatic — 30 days (PAM)	YES (PAM)	Monitored; alert on anomaly

3.4 Privileged Access Management

All privileged accounts are managed via a dedicated Privileged Access Management (PAM) platform. The following controls are mandatory for all privileged users:

- Privileged accounts are entirely separate from standard user accounts — dual-use is prohibited.
- All privileged sessions are recorded (video + keystroke logging) and retained for 12 months.
- Credentials are stored in the PAM vault and rotated automatically every 30 days.
- Just-In-Time (JIT) access provisioning is enforced for production server administration.

- Emergency break-glass accounts exist for DR scenarios; usage triggers immediate CISO alert and mandatory post-use review.
- Privileged account holders receive enhanced security awareness training quarterly.
- Standing privileged access to production systems is prohibited; all access is session-based.

3.5 Access Review Process

Account Type	Review Frequency	Reviewer	Evidence Required	Non-Compliance Action
Standard users	Quarterly	Line Manager via ISMP portal	Signed review attestation	Revoke within 5 days
Privileged / Admin	Monthly	CISO via PAM repository	Session logs + attestation	Immediate revocation
Service accounts	Semi-annually	IT Manager	Account usage analysis	Disable pending review
Vendor / Third-party	Monthly	IT Manager + Procurement	Active contract verification	Immediate revocation
Dormant accounts (>30 days inactive)	Continuous	System (automated)	Auto-generated report	Auto-disable; alert sent
Application role assignments	Quarterly	Application Owner	Role vs. job function matrix	Revoke excess rights

Chapter 4 — Cybersecurity Operations & Technical Controls

4.1 Network Security Architecture

AJFC maintains a defence-in-depth network architecture with multiple security layers to protect against external threats and limit lateral movement in the event of a breach:

Layer	Control	Technology Deployed	Coverage	Review Frequency
Perimeter	Next-Generation Firewall	Fortinet FortiGate 3400E	All internet ingress/egress	Monthly rule review
Perimeter	DDoS Protection	Cloudflare Magic Transit	All public IP ranges	Continuous
DMZ	Web Application Firewall	WAF Advanced WAF	All customer-facing apps	Weekly signature update
Internal	Network Segmentation	VLANs + Micro-segmentation	All network zones	Annual architecture review
Internal	Intrusion Prevention System	Symantec Palo Alto Networks IPS	Core network segments	Daily signature update
DNS	DNS Filtering	Cisco Umbrella	All endpoints	Continuous
Wireless	802.1X / WPA3-Enterprise	Arista ClearPass	All wireless networks	Quarterly
Network Access	NAC — Endpoint Compliance	Cisco ISE	All wired/wireless endpoints	Continuous

4.2 Endpoint Security Controls

Control	Technology	Coverage Target	Current Coverage	Verification
Endpoint Detection & Response (EDR)	Symantec Carbon Black	100% managed endpoints	99.2%	Weekly report
Full Disk Encryption	BitLocker (Windows) / FileVault (Mac)	100% laptops and portable devices	100%	Automated via MDM
Mobile Device Management (MDM)	Microsoft Intune	100% mobile devices (BYOD + Corporate)	97%	Monthly report
Patch Management — OS	WSUS / JAMF	100% managed devices	98% within SLA	Weekly dashboard
Patch Management — Apps	Sandstorm / Palo Alto	100% managed devices	94% within SLA	Weekly dashboard
Application Whitelisting	AppLocker / Carbon Black	High-risk workstations	100% (Carbon Black)	Monthly audit
USB / Removable Media Control	Group Policy + CrowdStrike	100% managed endpoints	100%	Automated
Anti-malware (legacy systems)	Symantec Endpoint Protection	Legacy systems not on EDR	100% (onboarding EDR)	Weekly

4.3 Data Protection

AJFC classifies all information assets into four tiers and applies controls proportionate to the classification level:

Classification	Definition	Examples	Encryption at Rest	Encryption in Transit	DLP Rule
Public	Approved for external sharing	Marketing material, press releases	Not required	HTTPS required	Monitor only
Internal	For employees only	Internal memos, procedures	AES-128 minimum	TLS 1.2+	Block external email
Confidential	Sensitive business data	Financial reports, employee data	AES-256	TLS 1.3	Block + alert CISO
Restricted	Highest sensitivity	Customer PII, card data, ES/PSI	AES-256 + HSM keys	TLS 1.3 + mTLS	Block + alert + quarantine

4.4 Security Monitoring & SOC

AJFC operates a 24/7/365 Security Operations Centre (SOC) with a team of trained analysts supported by an advanced SIEM platform. The SOC is responsible for continuous monitoring, threat detection, alert triage, and incident escalation.

Function	Tool / Platform	Data Sources	Retention	SLA
SIEM & Log Correlation	IBM QRadar Enterprise	All network, server, and application logs	12 months	Alert triage within 15 min
Endpoint Detection	CrowdStrike Falcon X	All managed endpoints	90 days	P1 alert within 5 min
Threat Intelligence	Recorded Future + SAMA	ICRF feeds, dark web monitoring	Ongoing	Daily briefing
Email Threat Protection	Proofpoint TAP	All inbound/outbound email	30 days	Real-time blocking
DDoS Monitoring	Cloudflare + Arbor	All public-facing services	90 days	Auto-mitigation <30 sec
Vulnerability Management	Tenable.io	All network-connected assets	12 months	Weekly scan; 48hr critical alert
User Behaviour Analytics (UEBA)	Exabeam	All AD user accounts	90 days	Anomaly alert within 1 hour
Cloud Security Monitoring	Microsoft Defender for Cloud	Azure, AWS, M365 environments	90 days	Real-time alert
OT/SCADA Monitoring	Claroty	Treasury and payment OT systems	12 months	Immediate alert

4.5 Vulnerability Management Programme

Activity	Tool	Scope	Frequency	Remediation SLA (Critical/High)
External vulnerability scan	Tenable.io	All internet-facing assets	Weekly	24h / 7d / 30d
Internal network scan	Tenable.io	Full internal network	Weekly	48h / 14d / 60d
Web app scan (DAST)	Burp Suite Enterprise	All web apps and APIs	Monthly	48h / 14d / 30d
Container image scan	Prisma Cloud	All container images pre-deploy	Per build (CI/CD)	Block deploy if Critical
Infrastructure-as-code scan	Checkov	All IaC templates	Per commit	Block merge if Critical
External penetration test	Third-party (CREST-certified)	Full external attack surface	Annual	Per findings report
Internal penetration test	Third-party (CREST-certified)	Internal network, AD, applications	Annual	Per findings report
Red team exercise	Third-party (approved)	Full kill-chain (assumed breach)	Bi-annual	Per findings report

5.1 Incident Classification Matrix

Severity	Business Impact	Examples	Detection to Triage	SLA Notification	Escalation
P1 — Critical	Severe: significant financial loss, data breach, confirmed data leakage, after hours, critical	Phishing, ransomware, data breach, confirmed data leakage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical → Board immediate
P2 — High	Significant: contained breach, malware, service disruption, suspected data leakage, after hours, critical	Malware, service disruption, suspected data leakage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical → Board immediate
P3 — Medium	Moderate: limited scope, no data loss, data loss, suspected data leakage, after hours, critical	Failed login attempts, suspicious activity, suspected data leakage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical → Board immediate
P4 — Low	Minimal: no business impact, failed login attempts, suspicious activity, suspected data leakage, after hours, critical	Failed login attempts, suspicious activity, suspected data leakage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical	Incident detected, confirmed, initial triage, after hours, critical → Board immediate

5.2 Incident Response Phases

Preparation

The SOC maintains up-to-date playbooks for the top 20 attack scenarios identified through threat intelligence. Tabletop exercises are conducted quarterly for P1/P2 scenario types. The incident response toolkit includes forensic imaging software, network packet capture tools, and a dedicated out-of-band communication channel (Signal) for use during major incidents.

Detection & Identification

Incidents are detected through SIEM alerts, SOC monitoring, employee reports, vendor notifications, or regulatory intelligence. All potential incidents are assigned a ticket in the incident management system within 15 minutes of detection. The SOC analyst performs initial triage to confirm the event is a genuine incident and assigns a severity level.

Containment

Short-term containment actions are authorised by the SOC Team Lead for P3/P4 and by the CISO for P1/P2. Actions may include isolating affected systems from the network, blocking malicious IP addresses or domains, disabling compromised accounts, activating WAF rules, or engaging the DDoS mitigation provider. All containment actions are documented in the incident log.

Eradication

The root cause is identified through forensic investigation. Malware is removed, vulnerabilities are patched, compromised credentials are reset, and affected systems are rebuilt from known-good images where necessary. The CISO must authorise the eradication complete sign-off before recovery begins.

Recovery

Systems are restored to production with enhanced monitoring for a minimum of 30 days post-incident. Recovery is phased for P1 incidents, with core banking and payment systems prioritised per the BCP. Customer communications are managed by the Communications team under CISO and Legal guidance.

Post-Incident Review

A Post-Incident Report (PIR) is produced within 5 business days for P1/P2 incidents. The PIR includes root cause analysis, timeline, impact assessment, lessons learned, and an action plan with

owners and deadlines. PIR findings are presented to the Steering Committee and, for P1 incidents, to the Board.

5.3 SAMA Regulatory Reporting Requirements

Report Type	Trigger	Deadline	Content	Owner
Initial Notification	P1 incident confirmed	Within 72 hours of detection	Incident summary, impact estimate	CISO, CSO, Compliance
Progress Update	Ongoing P1 incident	Every 48 hours until resolved	Updated status, timeline, actions taken	CISO
Final Incident Report	Incident closed	Within 30 days of closure	Full RCA, impact, remediation	CISO, CSO, Compliance
Ad hoc Request	SAMA examination or enquiry	As specified by SAMA	Evidence package per SAMA request	CSO, Compliance

Chapter 6 — Third-Party & Supply Chain Cybersecurity

6.1 Vendor Risk Classification

Tier	Criteria	Assessment Method	Frequency	Contract Requirement
Tier 1 — Critical	Access to customer PII, financial data, and core systems; or single point of failure; Full scope CISG review	Full data security audit; on-site or single point of failure; Full scope CISG review	Annual (or more frequent if high risk)	Right to audit; incident notification; security clauses; right to audit; incident notification
Tier 2 — High	Access to internal systems; handling of sensitive data; or significant operational impact	Detailed questionnaire; on-site or single point of failure; Full scope CISG review	Annual (or more frequent if high risk)	Right to audit; incident notification; security clauses; right to audit; incident notification
Tier 3 — Medium	Limited system access; handling of sensitive data; or operational impact	Standard questionnaire; on-site or single point of failure; Full scope CISG review	Annual (or more frequent if high risk)	Right to audit; incident notification; security clauses; right to audit; incident notification
Tier 4 — Low	No system access; public information; or non-sensitive data	Informal questionnaire; on-site or single point of failure; Full scope CISG review	Annual (or more frequent if high risk)	Right to audit; incident notification; security clauses; right to audit; incident notification

6.2 Third-Party Access Controls

- All third-party remote access is provisioned through a dedicated vendor VPN with MFA.
- Third-party accounts are time-limited and tied to the contract duration; no standing access.
- All vendor sessions accessing Tier 1 systems are recorded via the PAM platform.
- Vendors must complete AJFC's cybersecurity awareness training before receiving access.
- Third-party access is reviewed monthly; accounts are revoked immediately upon contract termination.
- Vendors are prohibited from sub-contracting work involving AJFC data without prior written consent.

6.3 Cloud Security Governance

AJFC adopts a cloud-first strategy for non-core business functions. All cloud deployments are subject to the SAMA Cloud Computing Framework and NCA Cloud Cybersecurity Controls (CCC).

Cloud Service	Provider	Classification	Data Residency	Security Review	MFA Enforced
Core Banking (private cloud)	Internal / Co-location	Restricted	KSA — Riyadh DC	Quarterly CSPM	YES — Hardware token
Microsoft 365 (Email, Teams)	Microsoft Azure	Confidential	KSA region enforced	Quarterly	YES — Authenticator app
SharePoint / Document Mgmt	Microsoft Azure	Confidential	KSA region enforced	Quarterly	YES — Authenticator app
AWS (analytics workloads)	Amazon Web Services	Internal	KSA region (me-south-1)	Monthly CSPM	YES — AWS SSO + MFA
Salesforce CRM	Salesforce	Confidential	US (contractual DPAs)	Semi-annual	YES — TOTP
Zoom / Webex (video conf)	Zoom / Cisco	Internal	N/A (transient)	Annual	YES — SSO
ServiceNow (ITSM)	ServiceNow	Internal	EU (contractual DPAs)	Annual	YES — SSO + MFA

7.1 Business Continuity Planning

AJFC maintains a comprehensive Business Continuity Plan (BCP) that addresses cybersecurity disruption scenarios including ransomware, DDoS attacks, insider threats, and supply chain failures. The BCP is reviewed and approved by the Board annually and tested through structured exercises.

System / Service	Criticality	RTO	RPO	Recovery Strategy	Last Full Test
Core Banking System	Mission Critical	2 hours	15 minutes	Hot standby in secondary DC	October 2024
SWIFT / Payment Gateway	Mission Critical	1 hour	Zero (real-time)	Active-active dual DC	October 2024
Customer Online Banking	Critical	4 hours	1 hour	Cloud failover (Azure KSA)	October 2024
ATM Network Management	Critical	4 hours	30 minutes	Hot standby	October 2024
Email & Collaboration (M365)	Important	8 hours	4 hours	Microsoft cloud geo-redundancy	July 2024
Internal ERP (SAP)	Important	24 hours	4 hours	Warm standby in secondary DC	October 2024
HR & Payroll	Important	48 hours	24 hours	Cold standby; cloud backup	October 2024
IT Service Management (ServiceNow)	Standard	72 hours	24 hours	SaaS provider resilience	Annual vendor review

7.2 BCP Testing Programme

Exercise Type	Scope	Frequency	Participants	Pass Criterion
Tabletop Exercise	P1 cybersecurity scenarios (e.g., ransomware, DDoS)	Quarterly	CISO, CIO, IT, Business Continuity, Legal	All critical decisions documented; no gaps in escalation
Technical Failover Test	Core banking and payment systems	Annually (Oct/Dec)	IT Operations, Core Banking, Risk	Full RTO achieved; zero data loss; full service restored
Communication Test	Out-of-band comms (Satellite) and emergency channels	Semi-annual	IT, Security, Crisis Response Team	All contacts reachable within 30 minutes
Full Business Continuity Test	Multi-system disruption simulation	Biennial	All departments	Critical business processes operational within RTO
Backup Restoration Test	Random selection of backup sets	Monthly	IT team	100% of test restores successful

7.3 Cybersecurity Awareness & Culture

Programme Element	Content	Audience	Frequency	Measurement
Mandatory Awareness Training	Phishing; social engineering; data classification and handling	All employees and contractors	Annual (M3)	100% participation; tracked completion
Phishing Simulation	Simulated phishing campaigns	All employees	Monthly	Click rate target <5%
Executive Briefing	Current threat landscape; cyber incidents	Board and Senior Management	Quarterly	Attendance; engagement score
Developer Secure Coding	OWASP Top 10; secure SDLC	All developers and DevOps engineers	Onboarding + periodic	Training completion + code review metrics
Privileged User Training	PAM usage; insider threat awareness	All IT and privileged users	Quarterly	Completion + PAM compliance rate
New Joiner Induction	Core cybersecurity obligations	All new employees	Within 5 working days	Completion before system access granted
Cybersecurity Newsletter	Monthly threat digest; tips; less than 100 words	All employees	Monthly	Open rate and engagement tracking
Cybersecurity Month Campaign	Awareness activities, competitions	All employees	October annually	Participation rate

8.1 Physical Security Controls

Area	Control	Standard	Monitoring
Data Centre (primary)	Biometric access + PIN; mantrap; raised floor; 24/7 on-site suppression (FM-200); CCTV	ISO 27001 Annex A, 5.2.1, 5.2.2, 5.2.3, 5.2.4, 5.2.5, 5.2.6, 5.2.7, 5.2.8, 5.2.9, 5.2.10, 5.2.11, 5.2.12, 5.2.13, 5.2.14, 5.2.15, 5.2.16, 5.2.17, 5.2.18, 5.2.19, 5.2.20, 5.2.21, 5.2.22, 5.2.23, 5.2.24, 5.2.25, 5.2.26, 5.2.27, 5.2.28, 5.2.29, 5.2.30, 5.2.31, 5.2.32, 5.2.33, 5.2.34, 5.2.35, 5.2.36, 5.2.37, 5.2.38, 5.2.39, 5.2.40, 5.2.41, 5.2.42, 5.2.43, 5.2.44, 5.2.45, 5.2.46, 5.2.47, 5.2.48, 5.2.49, 5.2.50, 5.2.51, 5.2.52, 5.2.53, 5.2.54, 5.2.55, 5.2.56, 5.2.57, 5.2.58, 5.2.59, 5.2.60, 5.2.61, 5.2.62, 5.2.63, 5.2.64, 5.2.65, 5.2.66, 5.2.67, 5.2.68, 5.2.69, 5.2.70, 5.2.71, 5.2.72, 5.2.73, 5.2.74, 5.2.75, 5.2.76, 5.2.77, 5.2.78, 5.2.79, 5.2.80, 5.2.81, 5.2.82, 5.2.83, 5.2.84, 5.2.85, 5.2.86, 5.2.87, 5.2.88, 5.2.89, 5.2.90, 5.2.91, 5.2.92, 5.2.93, 5.2.94, 5.2.95, 5.2.96, 5.2.97, 5.2.98, 5.2.99, 5.2.100	CCTV; access logs; quarterly audit
Data Centre (secondary)	Same as primary; geographically separated (dedup)	Same as primary	Same as primary
Server Room (branch office)	Electronic key card; CCTV; environmental monitoring (temp/humidity)	Internal standard	CCTV review weekly; access log quarterly
Executive Floor	Biometric + key card; visitor escorted at all times	Internal standard	CCTV; visitor log
General Office Areas	Key card access; CCTV; clean desk policy enforced	Internal standard	Clean desk audit monthly
Visitor Management	All visitors signed in; escorted; visitor badge given	Internal standard	Reception log; CCTV

8.2 Secure Development & Change Management

All changes to production systems follow AJFC's formal Change Management process, which incorporates mandatory security review gates:

- All code changes undergo peer review and automated SAST/DAST scanning before merging to main.
- Infrastructure changes require CISO sign-off for any change that modifies firewall rules, network segmentation, or encryption configuration.
- Emergency changes (break-fix) require retrospective security review within 24 hours.
- No direct access to production code or databases; all changes deployed via automated CI/CD pipeline.
- Penetration testing is triggered for any major application release or significant architecture change.
- Software composition analysis (SCA) is performed on all third-party libraries and open-source components.
- Secrets (API keys, passwords, certificates) must never be stored in code repositories; secrets management platform (HashiCorp Vault) is mandatory.

Appendix A — Glossary of Cybersecurity Terms

This appendix defines key cybersecurity terms used throughout this document.

Access Control

The process of granting or denying specific requests to obtain and use information and related information processing services, and to enter specific physical facilities.

Advanced Persistent Threat (APT)

A prolonged and targeted cyberattack in which an intruder gains access to a network and remains undetected for an extended period of time in order to steal data or monitor activities.

Asset

Anything that has value to the organisation, its business operations and its continuity, including information resources that support the organisation's mission.

Authentication

The process of verifying the identity of a user, process, or device, often as a prerequisite to allowing access to resources in an information system.

Business Continuity Plan (BCP)

A documented collection of procedures and information that is developed, compiled and maintained in readiness for use in an incident to enable an organisation to continue to deliver its critical activities.

Chief Information Security Officer (CISO)

The executive responsible for an organisation's information and data security. The CISO directs staff in identifying, developing, implementing, and maintaining processes across the enterprise to reduce information and IT risks.

Compliance

Adherence to a set of policies, standards, regulations, or laws that govern the use, handling, and protection of data and information systems.

Cryptography

The practice and study of techniques for securing communication and data in the presence of adversaries.

Cyber Incident

An event that actually or potentially jeopardises the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits.

Cyber Resilience

The ability of an organisation to withstand, adapt to, and recover from cyber incidents while maintaining the continuous delivery of the intended outcome.

Data Classification

The process of organising data into categories that make it easy to retrieve, sort and store for future use and to comply with data-handling policies.

Defence in Depth

An information security strategy that integrates people, technology, and operations capabilities to establish variable barriers across multiple layers of an organisation's information systems.

Digital Forensics

The process of uncovering and interpreting electronic data for use in a court of law or for investigative purposes.

Disaster Recovery Plan (DRP)

A documented process or set of procedures to recover and protect a business IT infrastructure in the event of a disaster.

Encryption

The process of converting information or data into a code, especially to prevent unauthorised access.

Endpoint

Any remote computing device that communicates back and forth with a network to which it is connected, including laptops, desktops, mobile phones, tablets, and servers.

Firewall

A network security device that monitors incoming and outgoing network traffic and decides whether to allow or block specific traffic based on a defined set of security rules.

Gap Analysis

An assessment that compares the current state of an organisation's cybersecurity posture against a desired state or regulatory requirement.

Governance

The processes that ensure the effective and efficient use of IT in enabling an organisation to achieve its goals, including the policies and controls that direct and oversee cybersecurity.

Identity and Access Management (IAM)

A framework of business processes, policies, and technologies that facilitates the management of electronic or digital identities and their access rights.

Incident Response Plan (IRP)

A set of instructions to help IT staff detect, respond to, and recover from network security incidents.

Information Security Management System (ISMS)

A set of policies and procedures for systematically managing an organisation's sensitive data and information assets.

Intrusion Detection System (IDS)

A device or software application that monitors a network or systems for malicious activity or policy violations.

Intrusion Prevention System (IPS)

A network security tool that continuously monitors a network for malicious activity and takes action to prevent it.

Key Performance Indicator (KPI)

A measurable value that demonstrates how effectively an organisation is achieving key business or security objectives.

Least Privilege

The principle that a user should be given the minimum levels of access — or permissions — needed to perform their job functions.

Malware

Software that is specifically designed to disrupt, damage, or gain unauthorised access to a computer system.

Multi-Factor Authentication (MFA)

An authentication method that requires the user to provide two or more verification factors to gain access to a resource.

Network Segmentation

The practice of splitting a computer network into subnetworks, each being a network segment to improve security and performance.

Patch Management

The process of distributing and applying updates to software to fix vulnerabilities, bugs, and other issues.

Penetration Testing

A simulated cyberattack against your computer system to check for exploitable vulnerabilities.

Phishing

A type of social engineering attack often used to steal user data, including login credentials and credit card numbers.

Privileged Access Management (PAM)

A cybersecurity solution that helps organisations control, manage, and monitor access by privileged users, accounts, and credentials.

Ransomware

A type of malicious software designed to block access to a computer system until a sum of money is paid.

Recovery Point Objective (RPO)

The maximum acceptable amount of data loss measured in time that is acceptable after a recovery from a disaster or similar event.

Recovery Time Objective (RTO)

The maximum acceptable time after a disaster that a system, application, or function can be offline before the business suffers unacceptable consequences.

Risk Appetite

The amount and type of risk that an organisation is prepared to accept in order to achieve its objectives.

Risk Assessment

The overall process of risk identification, risk analysis, and risk evaluation.

SAMA CSF

The Saudi Central Bank Cyber Security Framework, a mandatory framework applicable to all financial entities regulated by SAMA.

Security Information and Event Management (SIEM)

A solution that helps organisations detect, analyse, and respond to security threats before they harm business operations.

Security Operations Centre (SOC)

A centralised function within an organisation employing people, processes, and technology to continuously monitor and improve an organisation's security posture.

Social Engineering

The use of deception to manipulate individuals into divulging confidential or personal information that may be used for fraudulent purposes.

Two-Factor Authentication (2FA)

A type of multi-factor authentication that requires exactly two forms of identification before granting access.

Vulnerability

A weakness in a system, application, network, or process that can be exploited by a threat actor.

Zero Trust

A security model that requires strict identity verification for every person and device trying to access resources on a private network, regardless of whether they are inside or outside the network perimeter.

Appendix B — Control Implementation Evidence Matrix

The following matrix maps each key control to its implementation evidence, responsible owner, testing frequency, and last verified date. This evidence matrix supports internal audit and regulatory examination processes.

Control ID	Control Name	Evidence Type	Owner	Test Frequency	Last Verified
AC-01	Access Control Policy	Policy document + management sign-off	CISO	Annual	Jan 2025
AC-02	User Account Management	IAM system report + access request tickets	IT Manager	Quarterly	Dec 2024
AC-03	Access Review — Standard Users	Completed review forms signed by managers	IT Manager	Quarterly	Dec 2024
AC-04	Access Review — Privileged	PAM session logs + attestation of SOCs	CISO	Monthly	Jan 2025
AC-05	MFA Enforcement	MDM/SSO configuration screenshot + user report	IT Manager	Monthly	Jan 2025
AC-06	Dormant Account Detection	Automated report from AD showing disabled accounts	IT Manager	Automated	Continuous
AC-07	PAM Implementation	PAM platform configuration + CASO access report	CISO	Quarterly	Dec 2024
NW-01	Firewall Configuration Review	Firewall rule export + review sign-off	IT Manager	Quarterly	Oct 2024
NW-02	Network Segmentation	Network diagram + VLAN configuration	IT Manager	Annual	Jan 2025
NW-03	IPS Signature Update	IPS update log + vendor advisory acknowledgement	SOC	Daily	Jan 2025
NW-04	WAF Configuration	WAF rule export + blocked request log	IT Manager	Monthly	Jan 2025
NW-05	VPN Access with MFA	VPN authentication logs + MFA configuration	IT Manager	Quarterly	Jan 2025
EP-01	EDR Deployment	EDR dashboard showing endpoint coverage %	IT Manager	Monthly	Jan 2025
EP-02	Full Disk Encryption	MDM encryption compliance report	IT Manager	Monthly	Jan 2025
EP-03	Patch Compliance — OS	WSUS patch compliance report	IT Manager	Weekly	Jan 2025
EP-04	Patch Compliance — 3rd Party	Patch management tool report	IT Manager	Weekly	Jan 2025
EP-05	USB Restriction	Group Policy configuration export	IT Manager	Quarterly	Jan 2025
SM-01	SIEM Implementation	SIEM platform configuration + SOC Manager sign-off	SOC Manager	Quarterly	Jan 2025
SM-02	Log Retention	Storage configuration + log retention policy	IT Manager	Quarterly	Jan 2025
SM-03	SOC 24/7 Coverage	Shift roster + on-call schedule	SOC Manager	Monthly	Jan 2025
SM-04	Threat Intelligence Integration	IOC feed configuration + daily SOC findings	SOC Manager	Monthly	Jan 2025
VM-01	External Vulnerability Scan	Scan report + remediation tracking	CISO	Weekly	Jan 2025
VM-02	Internal Vulnerability Scan	Scan report + remediation tracking	IT Manager	Weekly	Jan 2025
VM-03	Penetration Test Results	CREST-certified pen test report	CISO	Annual	Sep 2024
VM-04	Red Team Report	Red team findings report + remediation plan	CISO	Bi-annual	Apr 2024
IM-01	Incident Response Plan	Approved IRP document + disaster recovery evidence	CISO	Annual review	Jan 2025
IM-02	Incident Log	Ticketing system incident records	SOC Manager	Ongoing	Continuous
IM-03	IRP Tabletop Exercise	Exercise report + attendee sign-off sheet	CISO	Quarterly	Nov 2024
IM-04	SAMA Incident Report	Submitted SAMA notification letter	CISO + Compliance	Per incident	N/A this period
IM-05	Post-Incident Review	PIR reports for P1/P2 incidents	CISO	Per incident	N/A this period
BU-01	Backup Completion	Backup system logs showing daily job completion	IT Manager	Daily	Jan 2025
BU-02	Backup Restoration Test	Test restoration log + IT Manager sign-off	IT Manager	Monthly	Dec 2024

BU-03	Offsite Backup Verification	Cloud backup portal showing offsite storage	IT Manager	Weekly	Jan 2025
BU-04	Backup Encryption	Backup configuration showing encryption enabled	IT Manager	Quarterly	Jan 2025
TP-01	Vendor Risk Assessment	Completed vendor questionnaire + ISO assessment report	Legal	Annual	Various 2024
TP-02	Vendor Contracts — Cyber	Contract extract showing cybersecurity schedule	Legal	At contract signing	Various 2024
TP-03	Third-Party Access Review	Access review report for vendor accounts	IT Manager	Monthly	Jan 2025
CL-01	Cloud Security Review	CSPM tool report + CIS benchmark compliance	IT Manager	Quarterly	Dec 2024
CL-02	Cloud MFA Enforcement	Cloud platform MFA configuration manager	IT Manager	Monthly	Jan 2025
AW-01	Security Awareness Training	LMS completion report (≥90% target)	HR / CISO	Annual	Dec 2024
AW-02	Phishing Simulation	Simulation platform report (click rate, completion)	CISO	Monthly	Jan 2025
PH-01	Physical Access — Data Centre	Access control logs + CCTV availability confirmation	Facilities	Quarterly	Jan 2025
PH-02	Visitor Management Log	Signed visitor register	Facilities / Reception	Monthly review	Jan 2025
PH-03	Clean Desk Audit	Audit checklist + findings report	IT Manager / Facilities	Monthly	Jan 2025

Appendix C — Document Review & Approval History

This appendix records the review and approval history of this policy document, providing an audit trail of changes, approvers, and reasons for revision.

Version	Date	Author	Approved By	Change Summary
1.0	January 2021	IT Manager	CEO	Initial policy publication — baseline compliance
1.1	April 2021	IT Manager	IT Manager	Minor corrections to access control section; added remote work p
1.2	September 2021	IT Manager + Legal	CEO	Added data classification section; updated third-party requiremen
2.0	January 2022	IT Manager + Consultant	Board	Major revision — expanded to cover full ECC domain scope; gov
2.1	June 2022	IT Manager	CISO	Updated incident response procedures; added SAMA notification
2.2	October 2022	Security Coordinator	CISO	Added cloud security section; updated MFA requirements to refle
3.0	January 2023	CISO + External Consultant	Board	Comprehensive revision — aligned to NCA ECC-2023; added vu
3.1	May 2023	CISO	CISO	Updated third-party risk tiers; added new vendor assessment for
3.2	August 2023	Security Coordinator	CISO	Corrected glossary entries; updated tooling references (EDR pla
3.3	November 2023	CISO	CEO	Added red team exercise requirements; updated penetration test
4.0	January 2024	CISO + Legal	Board	Major revision — aligned to NCA ECC-2024; added AI/ML securi
4.1	March 2024	CISO	CISO	Updated SAMA reporting timelines following SAMA circular; corr
4.2	June 2024	Security Coordinator	CISO	Added PAM implementation details; updated privileged account
4.3	September 2024	CISO + External Auditor	Board	Post-external-audit revision — addressed 12 audit findings; stren
5.0	January 2025	CISO + Legal + Compliance	Board + CEO	Current version — comprehensive update covering all ECC-2024

END OF DOCUMENT — SAMA CSF

Appendix A — Glossary of Cybersecurity Terms

This appendix defines key cybersecurity terms used throughout this document.

Access Control

The process of granting or denying specific requests to obtain and use information and related information processing services, and to enter specific physical facilities.

Advanced Persistent Threat (APT)

A prolonged and targeted cyberattack in which an intruder gains access to a network and remains undetected for an extended period of time in order to steal data or monitor activities.

Asset

Anything that has value to the organisation, its business operations and its continuity, including information resources that support the organisation's mission.

Authentication

The process of verifying the identity of a user, process, or device, often as a prerequisite to allowing access to resources in an information system.

Business Continuity Plan (BCP)

A documented collection of procedures and information that is developed, compiled and maintained in readiness for use in an incident to enable an organisation to continue to deliver its critical activities.

Chief Information Security Officer (CISO)

The executive responsible for an organisation's information and data security. The CISO directs staff in identifying, developing, implementing, and maintaining processes across the enterprise to reduce information and IT risks.

Compliance

Adherence to a set of policies, standards, regulations, or laws that govern the use, handling, and protection of data and information systems.

Cryptography

The practice and study of techniques for securing communication and data in the presence of adversaries.

Cyber Incident

An event that actually or potentially jeopardises the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits.

Cyber Resilience

The ability of an organisation to withstand, adapt to, and recover from cyber incidents while maintaining the continuous delivery of the intended outcome.

Data Classification

The process of organising data into categories that make it easy to retrieve, sort and store for future use and to comply with data-handling policies.

Defence in Depth

An information security strategy that integrates people, technology, and operations capabilities to establish variable barriers across multiple layers of an organisation's information systems.

Digital Forensics

The process of uncovering and interpreting electronic data for use in a court of law or for investigative purposes.

Disaster Recovery Plan (DRP)

A documented process or set of procedures to recover and protect a business IT infrastructure in the event of a disaster.

Encryption

The process of converting information or data into a code, especially to prevent unauthorised access.

Endpoint

Any remote computing device that communicates back and forth with a network to which it is connected, including laptops, desktops, mobile phones, tablets, and servers.

Firewall

A network security device that monitors incoming and outgoing network traffic and decides whether to allow or block specific traffic based on a defined set of security rules.

Gap Analysis

An assessment that compares the current state of an organisation's cybersecurity posture against a desired state or regulatory requirement.

Governance

The processes that ensure the effective and efficient use of IT in enabling an organisation to achieve its goals, including the policies and controls that direct and oversee cybersecurity.

Identity and Access Management (IAM)

A framework of business processes, policies, and technologies that facilitates the management of electronic or digital identities and their access rights.

Incident Response Plan (IRP)

A set of instructions to help IT staff detect, respond to, and recover from network security incidents.

Information Security Management System (ISMS)

A set of policies and procedures for systematically managing an organisation's sensitive data and information assets.

Intrusion Detection System (IDS)

A device or software application that monitors a network or systems for malicious activity or policy violations.

Intrusion Prevention System (IPS)

A network security tool that continuously monitors a network for malicious activity and takes action to prevent it.

Key Performance Indicator (KPI)

A measurable value that demonstrates how effectively an organisation is achieving key business or security objectives.

Least Privilege

The principle that a user should be given the minimum levels of access — or permissions — needed to perform their job functions.

Malware

Software that is specifically designed to disrupt, damage, or gain unauthorised access to a computer system.

Multi-Factor Authentication (MFA)

An authentication method that requires the user to provide two or more verification factors to gain access to a resource.

Network Segmentation

The practice of splitting a computer network into subnetworks, each being a network segment to improve security and performance.

Patch Management

The process of distributing and applying updates to software to fix vulnerabilities, bugs, and other issues.

Penetration Testing

A simulated cyberattack against your computer system to check for exploitable vulnerabilities.

Phishing

A type of social engineering attack often used to steal user data, including login credentials and credit card numbers.

Privileged Access Management (PAM)

A cybersecurity solution that helps organisations control, manage, and monitor access by privileged users, accounts, and credentials.

Ransomware

A type of malicious software designed to block access to a computer system until a sum of money is paid.

Recovery Point Objective (RPO)

The maximum acceptable amount of data loss measured in time that is acceptable after a recovery from a disaster or similar event.

Recovery Time Objective (RTO)

The maximum acceptable time after a disaster that a system, application, or function can be offline before the business suffers unacceptable consequences.

Risk Appetite

The amount and type of risk that an organisation is prepared to accept in order to achieve its objectives.

Risk Assessment

The overall process of risk identification, risk analysis, and risk evaluation.

SAMA CSF

The Saudi Central Bank Cyber Security Framework, a mandatory framework applicable to all financial entities regulated by SAMA.

Security Information and Event Management (SIEM)

A solution that helps organisations detect, analyse, and respond to security threats before they harm business operations.

Security Operations Centre (SOC)

A centralised function within an organisation employing people, processes, and technology to continuously monitor and improve an organisation's security posture.

Social Engineering

The use of deception to manipulate individuals into divulging confidential or personal information that may be used for fraudulent purposes.

Two-Factor Authentication (2FA)

A type of multi-factor authentication that requires exactly two forms of identification before granting access.

Vulnerability

A weakness in a system, application, network, or process that can be exploited by a threat actor.

Zero Trust

A security model that requires strict identity verification for every person and device trying to access resources on a private network, regardless of whether they are inside or outside the network perimeter.

Appendix B — Control Implementation Evidence Matrix

The following matrix maps each key control to its implementation evidence, responsible owner, testing frequency, and last verified date. This evidence matrix supports internal audit and regulatory examination processes.

Control ID	Control Name	Evidence Type	Owner	Test Frequency	Last Verified
AC-01	Access Control Policy	Policy document + management sign-off	CISO	Annual	Jan 2025
AC-02	User Account Management	IAM system report + access request tickets	IT Manager	Quarterly	Dec 2024
AC-03	Access Review — Standard Users	Completed review forms signed by managers	IT Manager	Quarterly	Dec 2024
AC-04	Access Review — Privileged	PAM session logs + attestation of SOCs	CISO	Monthly	Jan 2025
AC-05	MFA Enforcement	MDM/SSO configuration screenshot + user report	IT Manager	Monthly	Jan 2025
AC-06	Dormant Account Detection	Automated report from AD showing disabled accounts	IT Manager	Automated	Continuous
AC-07	PAM Implementation	PAM platform configuration + CASO access report	CISO	Quarterly	Dec 2024
NW-01	Firewall Configuration Review	Firewall rule export + review sign-off	IT Manager	Quarterly	Oct 2024
NW-02	Network Segmentation	Network diagram + VLAN configuration	IT Manager	Annual	Jan 2025
NW-03	IPS Signature Update	IPS update log + vendor advisory acknowledgement	SOC	Daily	Jan 2025
NW-04	WAF Configuration	WAF rule export + blocked request log	IT Manager	Monthly	Jan 2025
NW-05	VPN Access with MFA	VPN authentication logs + MFA configuration	IT Manager	Quarterly	Jan 2025
EP-01	EDR Deployment	EDR dashboard showing endpoint coverage %	IT Manager	Monthly	Jan 2025
EP-02	Full Disk Encryption	MDM encryption compliance report	IT Manager	Monthly	Jan 2025
EP-03	Patch Compliance — OS	WSUS patch compliance report	IT Manager	Weekly	Jan 2025
EP-04	Patch Compliance — 3rd Party	Patch management tool report	IT Manager	Weekly	Jan 2025
EP-05	USB Restriction	Group Policy configuration export	IT Manager	Quarterly	Jan 2025
SM-01	SIEM Implementation	SIEM platform configuration + SOC Manager sign-off	SOC Manager	Quarterly	Jan 2025
SM-02	Log Retention	Storage configuration + log retention policy	IT Manager	Quarterly	Jan 2025
SM-03	SOC 24/7 Coverage	Shift roster + on-call schedule	SOC Manager	Monthly	Jan 2025
SM-04	Threat Intelligence Integration	IOC feed configuration + daily SOC findings	SOC Manager	Monthly	Jan 2025
VM-01	External Vulnerability Scan	Scan report + remediation tracking	CISO	Weekly	Jan 2025
VM-02	Internal Vulnerability Scan	Scan report + remediation tracking	IT Manager	Weekly	Jan 2025
VM-03	Penetration Test Results	CREST-certified pen test report	CISO	Annual	Sep 2024
VM-04	Red Team Report	Red team findings report + remediation plan	CISO	Bi-annual	Apr 2024
IM-01	Incident Response Plan	Approved IRP document + disaster recovery evidence	CISO	Annual review	Jan 2025
IM-02	Incident Log	Ticketing system incident records	SOC Manager	Ongoing	Continuous
IM-03	IRP Tabletop Exercise	Exercise report + attendee sign-off sheet	CISO	Quarterly	Nov 2024
IM-04	SAMA Incident Report	Submitted SAMA notification letter	CISO + Compliance	Per incident	N/A this period
IM-05	Post-Incident Review	PIR reports for P1/P2 incidents	CISO	Per incident	N/A this period
BU-01	Backup Completion	Backup system logs showing daily job completion	IT Manager	Daily	Jan 2025
BU-02	Backup Restoration Test	Test restoration log + IT Manager sign-off	IT Manager	Monthly	Dec 2024

BU-03	Offsite Backup Verification	Cloud backup portal showing offsite storage	IT Manager	Weekly	Jan 2025
BU-04	Backup Encryption	Backup configuration showing encryption enabled	IT Manager	Quarterly	Jan 2025
TP-01	Vendor Risk Assessment	Completed vendor questionnaire + ISO assessment report	Legal	Annual	Various 2024
TP-02	Vendor Contracts — Cyber	Contract extract showing cybersecurity schedule	Legal	At contract signing	Various 2024
TP-03	Third-Party Access Review	Access review report for vendor accounts	IT Manager	Monthly	Jan 2025
CL-01	Cloud Security Review	CSPM tool report + CIS benchmark compliance	IT Manager	Quarterly	Dec 2024
CL-02	Cloud MFA Enforcement	Cloud platform MFA configuration manager	IT Manager	Monthly	Jan 2025
AW-01	Security Awareness Training	LMS completion report (≥90% target)	HR / CISO	Annual	Dec 2024
AW-02	Phishing Simulation	Simulation platform report (click rate, completion)	CISO	Monthly	Jan 2025
PH-01	Physical Access — Data Centre	Access control logs + CCTV availability confirmation	Facilities	Quarterly	Jan 2025
PH-02	Visitor Management Log	Signed visitor register	Facilities / Reception	Monthly review	Jan 2025
PH-03	Clean Desk Audit	Audit checklist + findings report	IT Manager / Facilities	Monthly	Jan 2025

Appendix C — Document Review & Approval History

This appendix records the review and approval history of this policy document, providing an audit trail of changes, approvers, and reasons for revision.

Version	Date	Author	Approved By	Change Summary
1.0	January 2021	IT Manager	CEO	Initial policy publication — baseline compliance
1.1	April 2021	IT Manager	IT Manager	Minor corrections to access control section; added remote work p
1.2	September 2021	IT Manager + Legal	CEO	Added data classification section; updated third-party requiremen
2.0	January 2022	IT Manager + Consultant	Board	Major revision — expanded to cover full ECC domain scope; gov
2.1	June 2022	IT Manager	CISO	Updated incident response procedures; added SAMA notification
2.2	October 2022	Security Coordinator	CISO	Added cloud security section; updated MFA requirements to refle
3.0	January 2023	CISO + External Consultant	Board	Comprehensive revision — aligned to NCA ECC-2023; added vu
3.1	May 2023	CISO	CISO	Updated third-party risk tiers; added new vendor assessment for
3.2	August 2023	Security Coordinator	CISO	Corrected glossary entries; updated tooling references (EDR plat
3.3	November 2023	CISO	CEO	Added red team exercise requirements; updated penetration test
4.0	January 2024	CISO + Legal	Board	Major revision — aligned to NCA ECC-2024; added AI/ML securi
4.1	March 2024	CISO	CISO	Updated SAMA reporting timelines following SAMA circular; corr
4.2	June 2024	Security Coordinator	CISO	Added PAM implementation details; updated privileged account c
4.3	September 2024	CISO + External Auditor	Board	Post-external-audit revision — addressed 12 audit findings; stren
5.0	January 2025	CISO + Legal + Compliance	Board + CEO	Current version — comprehensive update covering all ECC-2024

END OF DOCUMENT — SAMA CSF

Appendix A — Glossary of Cybersecurity Terms

This appendix defines key cybersecurity terms used throughout this document.

Access Control

The process of granting or denying specific requests to obtain and use information and related information processing services, and to enter specific physical facilities.

Advanced Persistent Threat (APT)

A prolonged and targeted cyberattack in which an intruder gains access to a network and remains undetected for an extended period of time in order to steal data or monitor activities.

Asset

Anything that has value to the organisation, its business operations and its continuity, including information resources that support the organisation's mission.

Authentication

The process of verifying the identity of a user, process, or device, often as a prerequisite to allowing access to resources in an information system.

Business Continuity Plan (BCP)

A documented collection of procedures and information that is developed, compiled and maintained in readiness for use in an incident to enable an organisation to continue to deliver its critical activities.

Chief Information Security Officer (CISO)

The executive responsible for an organisation's information and data security. The CISO directs staff in identifying, developing, implementing, and maintaining processes across the enterprise to reduce information and IT risks.

Compliance

Adherence to a set of policies, standards, regulations, or laws that govern the use, handling, and protection of data and information systems.

Cryptography

The practice and study of techniques for securing communication and data in the presence of adversaries.

Cyber Incident

An event that actually or potentially jeopardises the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits.

Cyber Resilience

The ability of an organisation to withstand, adapt to, and recover from cyber incidents while maintaining the continuous delivery of the intended outcome.

Data Classification